KRL-ADM — IAM administration console — DORA · RTS 2024/1774 · Internal policy PSI-4 (Banque Kerlann, fictitious)

Banque Kerlann (fictitious) · KRL-ADM — IAM administration console

Prepared by: **Attest (AI-assisted)**
Auditor sign-off: **pending**
Owner: **IT department — IAM team**
Date: **2026-11-04 12:26**
Run: **20261104-122607-c399**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

OPINION AFTER REMEDIATION

Unsatisfactory

Basis for opinion

7 controls tested (7 conclusive) against: DORA — Article 9(4): access, strong authentication, change management · RTS 2024/1774 — Article 21: access control · Internal policy PSI-4 (Banque Kerlann, fictitious) — authentication and access. Tests run on 2026-11-04 12:26, environment: Demonstration pre-production. The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

7 controls tested	**7** findings	**0** findings closed and verified · 5 re-tested compliant, closure pending approval	**2** open findings
0 human approvals · 5 pre-approved (demo)	**40** sensitive data items masked in evidence	**4 min 00 s** audit duration	**$0.458 *** measured AI cost



Critical: 1 High: 3 Medium: 3 Low: 0

Key messages

- 7 findings across 7 controls: 1 critical, 3 high, 3 medium.
- 5 finding(s) re-tested compliant after a pre-approved change (not valid as an approval): closure pending owner approval, still counted in the opinion.
- 2 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-20261104-C399
Entity	Banque Kerlann (fictitious)
System	KRL-ADM — IAM administration console
System criticality	Supports critical or important functions (DORA)

Environment	Demonstration pre-production
Owner	IT department — IAM team
Lead auditor	Attest CI
Date	2026-11-04 12:26
Framework	DORA — Article 9(4): access, strong authentication, change management · RTS 2024/1774 — Article 21: access control · Internal policy PSI-4 (Banque Kerlann, fictitious) — authentication and access
Audited target	KRL-ADM IAM admin console (Banque Kerlann)
Work programme	existing catalogue reused · runs/studio/20261104-122607-c399/catalogue.json

In scope

- Authentication and session settings of the KRL-ADM console
- Accounts with access to the console
- Logging of administrative actions

Out of scope

- Intrinsic strength of MFA factors (robustness of authentication means)
- Central directory and identity federation
- Physical controls

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fixes are drafted by the audit tool itself (self-review threat): closing a finding requires independent approval by the system owner.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.1	Mandatory MFA for privileged administrator accounts	Critical	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2026-12-04
F-02	PSI-4.2	Mandatory MFA for users of critical system	High	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-02-02

F-03	PSI-4.6	Logging of administration actions	High	Non-compliant		Action plan	2027-02-02
F-04	PSI-4.7	No generic shared admin accounts	High	Non-compliant		Action plan	2027-02-02
F-05	PSI-4.3	Password length and complexity	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03
F-06	PSI-4.4	Account lockout after failed logins	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03
F-07	PSI-4.5	Inactive session timeout	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03

4. Detailed findings and controls

F-01 PSI-4.1 Mandatory MFA for privileged administrator accounts

Critical · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Verify MFA is enforced for all privileged admin accounts.

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

Threshold source: PSI-4.1

> *« Authentification multifacteur obligatoire pour tout compte à privilèges (administrateur). »*

CONDITION

Observed: `{"mfa_admin": false, "admin_total": 2, "admin_mfa_true": 0, "admin_mfa_values": [false, false]}`

Expected: `mfa_admin == true and 100% of users with role admin have mfa == true`

mfa_admin is False and 0 of 2 admin accounts have mfa true.

PROBABLE CAUSE

MFA enforcement disabled or admin account enrolled without MFA. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

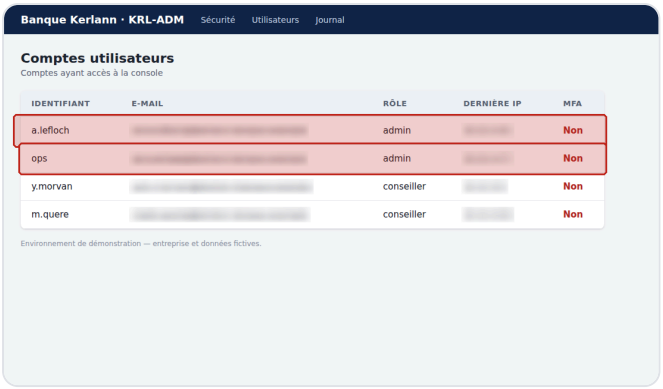
Admin takeover without second factor allows full compromise of critical IAM console.

RECOMMENDATION

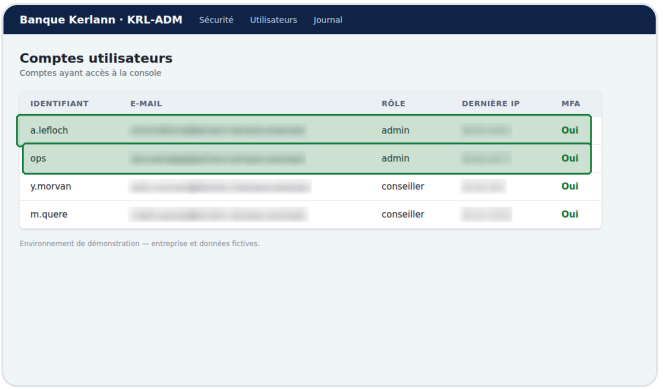
Enforce MFA for all admin accounts and re-verify enrollment within 30 days.

Due date: 2026-12-04 · Owner: IT department — IAM team

Test procedure: GET /api/security verify mfa_admin is true; GET /api/users verify every user with role admin has mfa true.



At testing — The screenshot corroborates the test. Screenshot shows both admin accounts with MFA Non, matching the failed test. · 8/8 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 12:26:59 · SHA-256 7bf17d9acfb0d5f2…`



After fix — The screenshot corroborates the test. Screenshot shows two admin accounts both with MFA Oui, matching the automated test result. · 8/8 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 12:29:54 · SHA-256 06d22cab84c2de8b…`

> **Change request CHG-AUD-20261104-C399-01** · `PATCH /api/security {"mfa_admin": true}`
> MFA enforcement for privileged accounts is disabled with 0 of 2 admins enrolled, violating PSI-4.1.
> Expected impact: The 2 admin accounts without MFA will be required to enroll at next login.
> Approved by: **System owner (CI)** · 2026-11-04 12:29:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T12:29:39Z · svc-change · mfa_admin: False → True

F-02 PSI-4.2 Mandatory MFA for users of critical system

High · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Verify MFA is enforced for all users of critical system KRL-ADM.

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

Threshold source: PSI-4.2

> *« Authentification multifacteur obligatoire pour les utilisateurs d'un système supportant une fonction critique ou importante. »*

CONDITION

Observed: `{"mfa_users": false, "total_users": 4, "mfa_true": 0, "users": [{"login": "a.lefloch", "mfa": false}, {"login": "ops", "mfa": false}, {"login": "y.morvan", "mfa…`

Expected: `mfa_users == true and 100% of users have mfa == true`

mfa_users is False and 0 of 4 users have mfa true

PROBABLE CAUSE

MFA enforcement for standard users disabled or users not enrolled. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

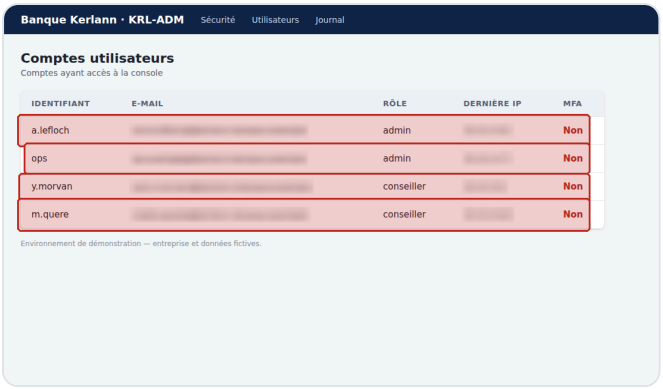
Account takeover of standard users on critical system enables lateral movement.

RECOMMENDATION

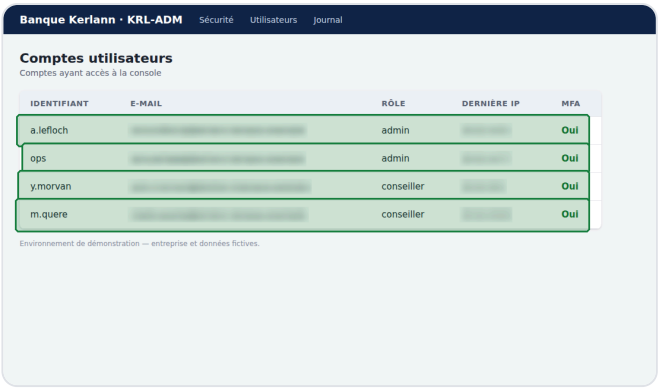
Enforce MFA for all users and re-verify enrollment within 90 days.

Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: GET /api/security verify mfa_users is true; GET /api/users verify every user has mfa true given KRL-ADM supports critical functions.



At testing — The screenshot corroborates the test. All four user rows show MFA status Non, matching the automated result of 0 of 4 users with MFA. · 8/8 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 12:28:09 · SHA-256 97a8a50563fb5e73…`



After fix — The screenshot corroborates the test. Screenshot shows four users all with MFA status Oui. · 8/8 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 12:29:55 · SHA-256 415182c0770b518d…`

> **Change request CHG-AUD-20261104-C399-02** · `PATCH /api/security {"mfa_users": true}`
> Enforce mandatory MFA for all standard users on critical system KRL-ADM as required by PSI-4.2.
> Expected impact: Standard users will be required to enroll in and use MFA at next login.
> Approved by: **System owner (CI)** · 2026-11-04 12:29:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T12:29:39Z · svc-change · mfa_users: False → True

F-03 PSI-4.6 Logging of administration actions

High · Non-compliant · Action plan

CRITERIA

Verify administration actions are logged.
PSI-4.6 · RTS 12(2)(c)(i)
Threshold source: PSI-4.6

> *« Journalisation de toutes les actions d'administration. »*

CONDITION

Observed: `{"admin_audit_log": true, "journal_count": 0}`
Expected: `admin_audit_log == true`
admin_audit_log is True with 0 journal entries.

PROBABLE CAUSE

Audit logging flag disabled. (AI hypothesis, not tested: to be confirmed with the owner)

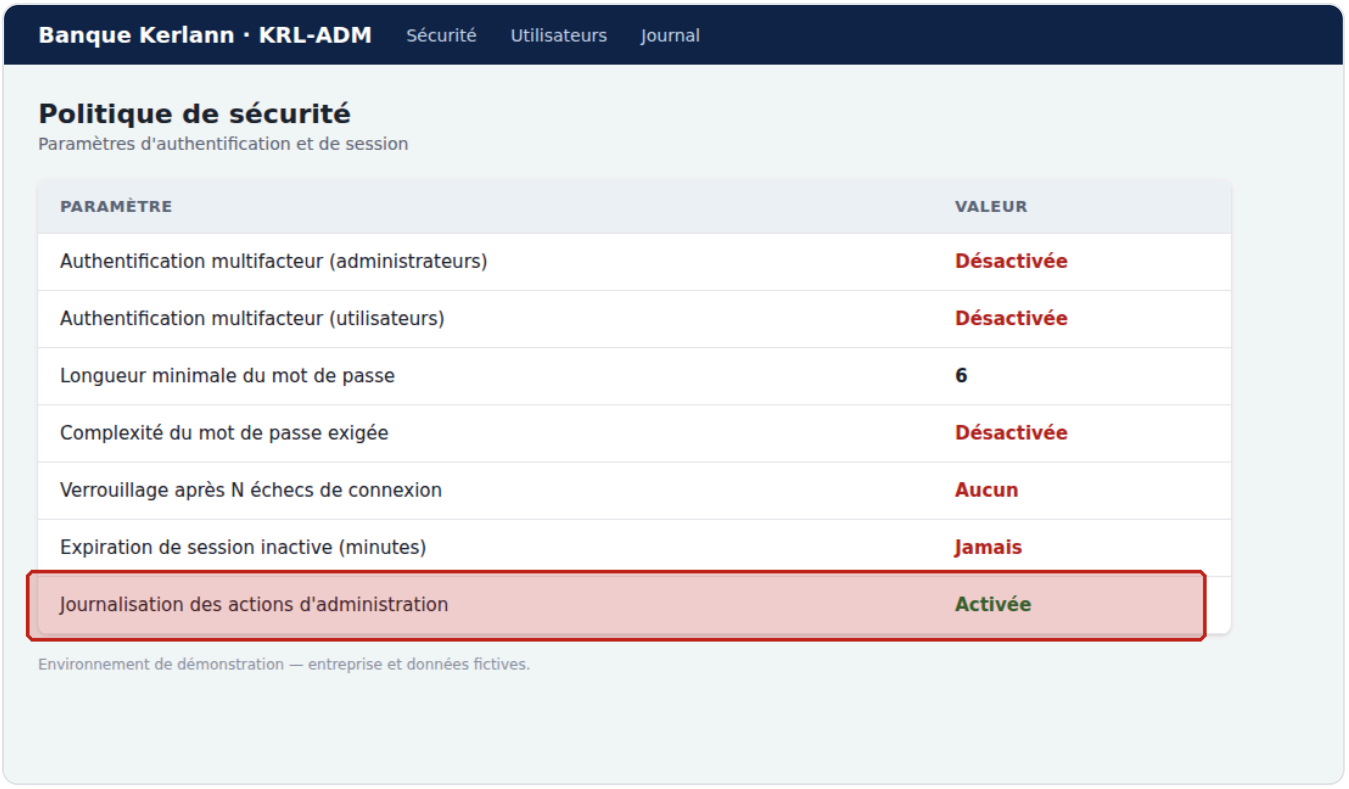
RISK

Missing admin logs prevent detection and forensic investigation.

RECOMMENDATION

Enable administration audit logging within 90 days.
Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: GET /api/security verify admin_audit_log is true; GET /api/journal confirm entries exist.



At testing — The screenshot corroborates the test. The screenshot shows Journalisation des actions d'administration as Activée, matching admin_audit_log true.
`2026-11-04 12:29:06 · SHA-256 e397a8e965fed320…`

Manual remediation · CHG-AUD-20261104-C399-03
admin_audit_log is already true so an empty journal cannot be fixed by a config toggle and requires human verification.

1. Verify via GET /api/security and /admin/security that admin_audit_log remains true.
2. Investigate journal backend, retention and filtering to explain why GET /api/journal returns 0 entries despite logging being enabled.
3. Perform one approved administration action and confirm a corresponding entry appears in /admin/journal with ticket, actor and approver.
4. Escalate to platform team if logging is broken and retain evidence for PSI-4.6 90-day follow-up.

F-04 PSI-4.7 No generic shared admin accounts

High · Non-compliant · Action plan

CRITERIA

Verify no admin role is held by a generic or shared account.
PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c) et 21(1)(e)(ii)
Threshold source: PSI-4.7

> *« Aucun compte générique ou partagé ne dispose de droits d'administration. »*

CONDITION

Observed: `[{"login": "ops", "email": "o•••@kerlann-banque.example"}]`
Expected: `0 users with role admin having generic login or shared mailbox`
Checked 2 admin accounts and found 1 with generic login or shared mailbox

PROBABLE CAUSE

Legacy functional admin account retained with admin role.
(AI hypothesis, not tested: to be confirmed with the owner)

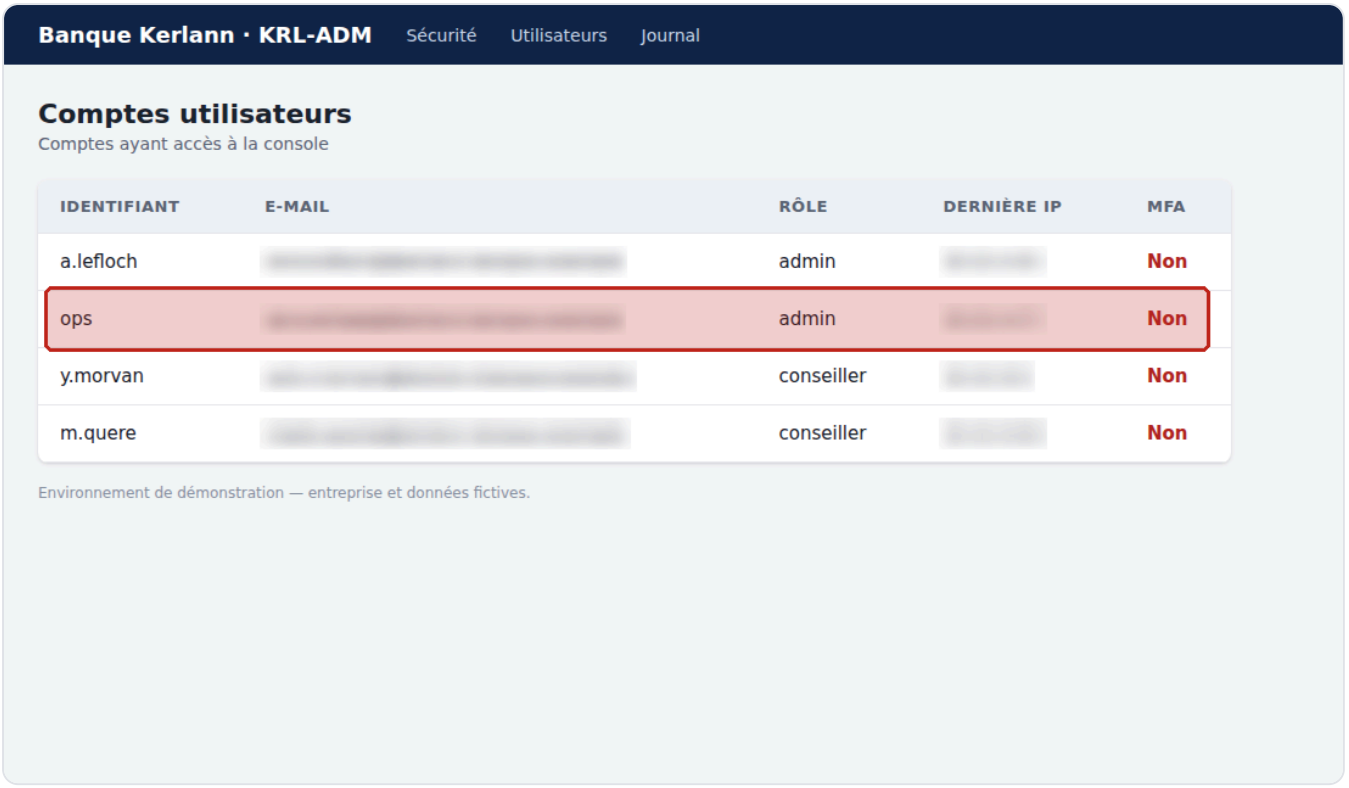
RISK

Shared admin accounts destroy accountability and enable undetected abuse.

RECOMMENDATION

Remove admin rights from generic accounts and replace with nominative initiale.nom accounts within 90 days.
Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: GET /api/users filter role admin; flag login without initiale.nom form (e.g. ops, admin, root) or email with shared box (ops-partage@, admin@).



At testing — The screenshot corroborates the test. The screenshot shows login ops with role admin, confirming the generic admin account flagged by the automated test. · 8/8 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 12:29:11 · SHA-256 ca5ca01e62a8a8fc…`

Manual remediation · CHG-AUD-20261104-C399-04
Shared admin accounts destroy accountability and enable undetected abuse.

1. Revoke admin role from generic account login 'ops' (o•••@kerlann-banque.example)
2. Provision nominative firstname.lastname admin accounts for authorized staff requiring privileged access
3. Verify via GET /api/users and /admin/users that 0 admin accounts have generic login or shared mailbox

F-05 PSI-4.3 Password length and complexity

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Verify 12-character minimum and complexity are enforced.

PSI-4.3 · DORA 9(4)(d) (bonnes pratiques)
Threshold source: PSI-4.3

> *« Mot de passe de 12 caractères minimum, avec exigence de complexité. »*

CONDITION

Observed: `{"password_min_length": 6, "password_require_complexity": false}`
Expected: `password_min_length >= 12 and password_require_complexity == true`
Observed password_min_length 6 and password_require_complexity false.

PROBABLE CAUSE

Weak password policy configuration. (AI hypothesis, not tested: to be confirmed with the owner)

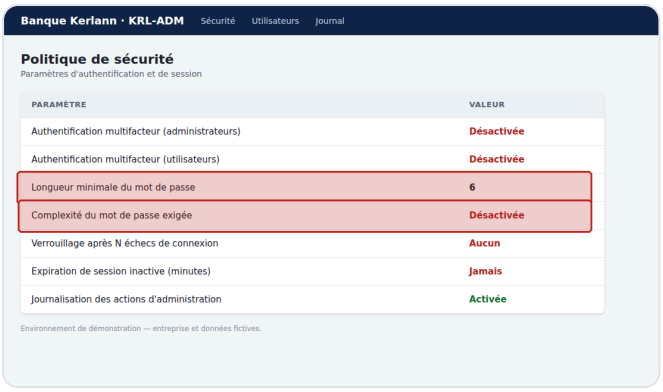
RISK

Weak passwords enable brute-force and credential stuffing.

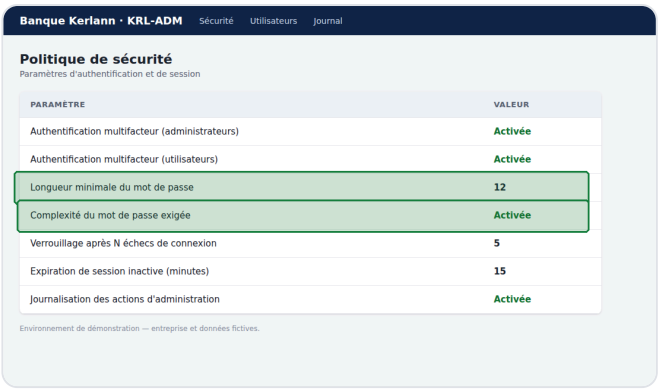
RECOMMENDATION

Set minimum length to 12 and enable complexity within 180 days.
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: GET /api/security check password_min_length and password_require_complexity.



At testing — The screenshot corroborates the test. Screenshot shows minimum length 6 and complexity disabled, matching the automated fail result.
`2026-11-04 12:27:28 · SHA-256 c062444b25f45b37…`



After fix — The screenshot corroborates the test. The screenshot shows minimum length 12 and complexity Activée, matching the automated test result.
`2026-11-04 12:29:56 · SHA-256 2afa528262e2d705…`

> **Change request CHG-AUD-20261104-C399-05** · `PATCH /api/security {"password_min_length": 12, "password_require_complexity": true}`
> Observed policy of 6 characters without complexity violates PSI-4.3 requiring 12 characters minimum with complexity.
> Expected impact: Users will be required to choose 12-character complex passwords at next creation or reset.
> Approved by: **System owner (CI)** · 2026-11-04 12:29:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T12:29:39Z · svc-change · password_min_length: 6 → 12; password_require_complexity: False → True

F-06 PSI-4.4 Account lockout after failed logins

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Verify lockout occurs after at most 5 failures and is enabled.

PSI-4.4 · DORA 9(4)(c)

Threshold source: PSI-4.4

> *« Verrouillage du compte après 5 échecs de connexion au plus (et jamais désactivé). »*

CONDITION

Observed: `0`

Expected: `1 <= lockout_threshold <= 5 (0 fails as never locks)`

lockout_threshold is 0, not within 1 to 5 or disabled.

PROBABLE CAUSE

Lockout disabled or threshold set too high. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

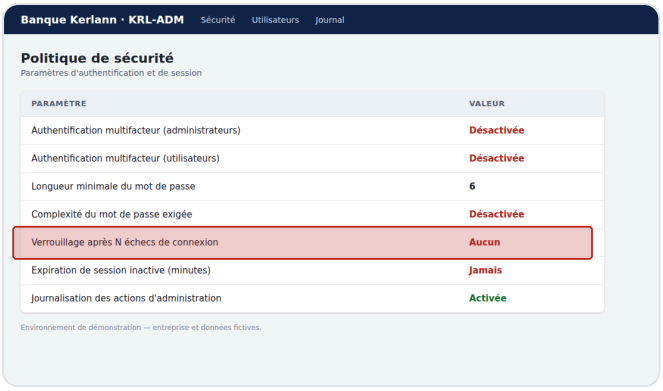
No lockout allows unlimited password guessing.

RECOMMENDATION

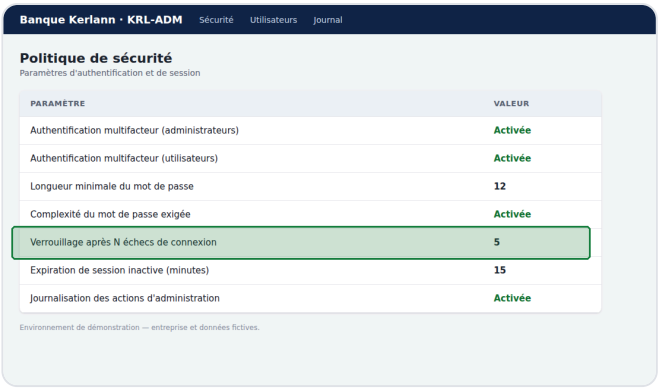
Set lockout threshold to 5 or less and never to 0 within 180 days.

Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: GET /api/security check lockout_threshold.



At testing — The screenshot corroborates the test. The screenshot shows lockout set to Aucun, confirming the automated finding of disabled lockout.
`2026-11-04 12:27:32 · SHA-256 013a9eceeb05ebc4…`



After fix — The screenshot corroborates the test. The security policy table shows lockout after 5 failed logins, matching the automated test value of 5.
`2026-11-04 12:29:56 · SHA-256 61ee6e5268a23f0b…`

> **Change request CHG-AUD-20261104-C399-06** · `PATCH /api/security {"lockout_threshold": 5}`
> Lockout is disabled with threshold 0, so set it to 5 to meet PSI-4.4 requirement of 1 to 5.
> Expected impact: Users will be locked out after 5 consecutive failed logins and will require unlock or reset.
> Approved by: **System owner (CI)** · 2026-11-04 12:29:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T12:29:39Z · svc-change · lockout_threshold: 0 → 5

F-07 PSI-4.5 Inactive session timeout

Medium **Non-compliant** → **Compliant**

Re-tested compliant — closure pending owner approval

CRITERIA

Verify inactive sessions expire after at most 15 minutes.
PSI-4.5 · DORA 9(4)(c)
Threshold source: PSI-4.5

> *« Expiration des sessions inactives après 15 minutes au plus (et jamais désactivée). »*

CONDITION

Observed: `{"session_timeout_minutes": 0}`
Expected: `1 <= session_timeout_minutes <= 15 (0 fails as never expires)`
session_timeout_minutes is 0 minutes (never expires).

PROBABLE CAUSE

Session timeout disabled or set too long. (AI hypothesis, not tested: to be confirmed with the owner)

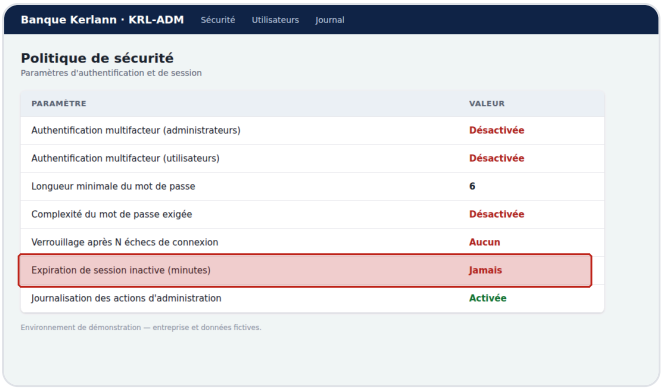
RISK

Abandoned sessions allow hijacking on shared workstations.

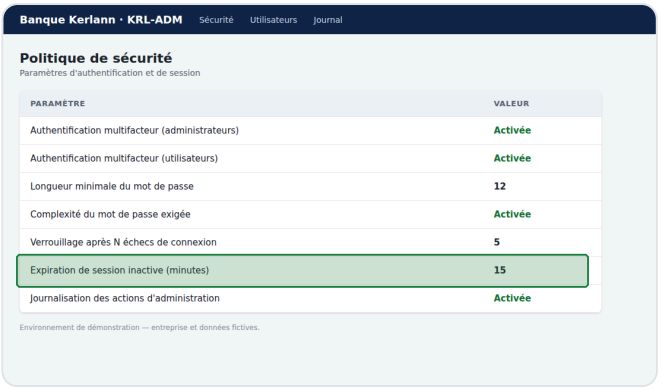
RECOMMENDATION

Set inactive timeout to 15 minutes or less and never to 0 within 180 days.
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: GET /api/security check session_timeout_minutes.



At testing — The screenshot corroborates the test. The screenshot shows inactive session expiration set to Jamais, confirming the timeout is disabled.
`2026-11-04 12:28:13 · SHA-256 f45754e50dd20564…`



After fix — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 15 minutes, matching the test result.
`2026-11-04 12:30:06 · SHA-256 587fddb3679d8bfc…`

> **Change request CHG-AUD-20261104-C399-07** · `PATCH /api/security {"session_timeout_minutes": 15}`
> Set inactive session timeout to 15 minutes to satisfy PSI-4.5.
> Expected impact: Users inactive for 15 minutes will be logged out and must re-authenticate.
> Approved by: **System owner (CI)** · 2026-11-04 12:29:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T12:29:39Z · svc-change · session_timeout_minutes: 0 → 15

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged administrator accounts	7d2bd2c3e9c8860f · written by AI for this engagement	Non-compliant → Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	957088ec558b321e · written by AI for this engagement	Non-compliant → Compliant
DORA 9(4)(d) (bonnes pratiques)	PSI-4.3	C3 · Password length and complexity	7c6668725bc1f0e8 · written by AI for this engagement	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	2f7fc0c5c4bbee6c · written by AI for this engagement	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	6ee42a251d9c91d1 · written by AI for this engagement	Non-compliant → Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	6c4d3457aca59ff1 · written by AI for this engagement	Non-compliant
DORA 9(4)(c), RTS 21(1)(c) et 21(1)(e)(ii)	PSI-4.7	C7 · No generic shared admin accounts	3793a8e5127ce544 · written by AI for this engagement	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-04 12:26:59	7bf17d9acfb0d5f28ad622f3c11a10c7e09df59cc13c7209a1aabd30105c5622
evidence/C1_after.png	C1 · After fix	2026-11-04 12:29:54	06d22cab84c2de8b3f7e0bfca33ba4fbd23a331892232ac8e33164e44a53878c
evidence/C2_before.png	C2 · At testing	2026-11-04 12:28:09	97a8a50563fb5e7353124ab6d9c471b199d2c9693e7dafda4e2b9e347c6d2bd8
evidence/C2_after.png	C2 · After fix	2026-11-04 12:29:55	415182c0770b518dceda72130b7c6297dee1d2e69b08a9b62047eb455de47f49
evidence/C3_before.png	C3 · At testing	2026-11-04 12:27:28	c062444b25f45b3730865ae70aa5304ace226677a2ba4b7d08c33e3fe49cabc3
evidence/C3_after.png	C3 · After fix	2026-11-04 12:29:56	2afa528262e2d705839e49a6a958bca94e19447be0312f1d98cca2d9f570695f
evidence/C4_before.png	C4 · At testing	2026-11-04 12:27:32	013a9eceeb05ebc41dc91f9e1f7fb05196b9a54977b326825a0609642d5e84c8
evidence/C4_after.png	C4 · After fix	2026-11-04 12:29:56	61ee6e5268a23f0bba15b5fbe15ae81148bf7d33496e5df9802d2ebfda1ba437
evidence/C5_before.png	C5 · At testing	2026-11-04 12:28:13	f45754e50dd20564b8a712f28adbc651771f1f2c294feff18f9c9235dbb4b1f0
evidence/C5_after.png	C5 · After fix	2026-11-04 12:30:06	587fddb3679d8bfc8c085929eb59fce6e6ae71b3d7babdb9cc3b417a708b9946
evidence/C6_before.png	C6 · At testing	2026-11-04 12:29:06	e397a8e965fed320d96525f43194a0694cb93d8c582a77daba03a529502afebd

evidence/C7_before.png	C7 · At testing	2026-11-04 12:29:11	ca5ca01e62a8a8fc33e86dadccdda6133c931a52a5ff4dfd9ce12686c2831dae
evidence/journal.png	System journal		4289438599f269956ba978ff71d4f12c78b28cbd0fc84e886fd356b574bfa0e4

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	27	34,283	97,620	0	0.4577
sam-3.1	12	0	0	12	price not published
Total					**0.4577**

Sensitive data (personal data and secrets) in evidence: 0/40 spotted by Muse Spark + SAM, 40/40 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Human decisions

TICKET	REF.		APPROVED BY	MODE	DATE
CHG-AUD-20261104-C399-01	F-01	✔	System owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 12:29:39
CHG-AUD-20261104-C399-02	F-02	✔	System owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 12:29:39
CHG-AUD-20261104-C399-05	F-05	✔	System owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 12:29:39
CHG-AUD-20261104-C399-06	F-06	✔	System owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 12:29:39
CHG-AUD-20261104-C399-07	F-07	✔	System owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 12:29:39

Safeguards

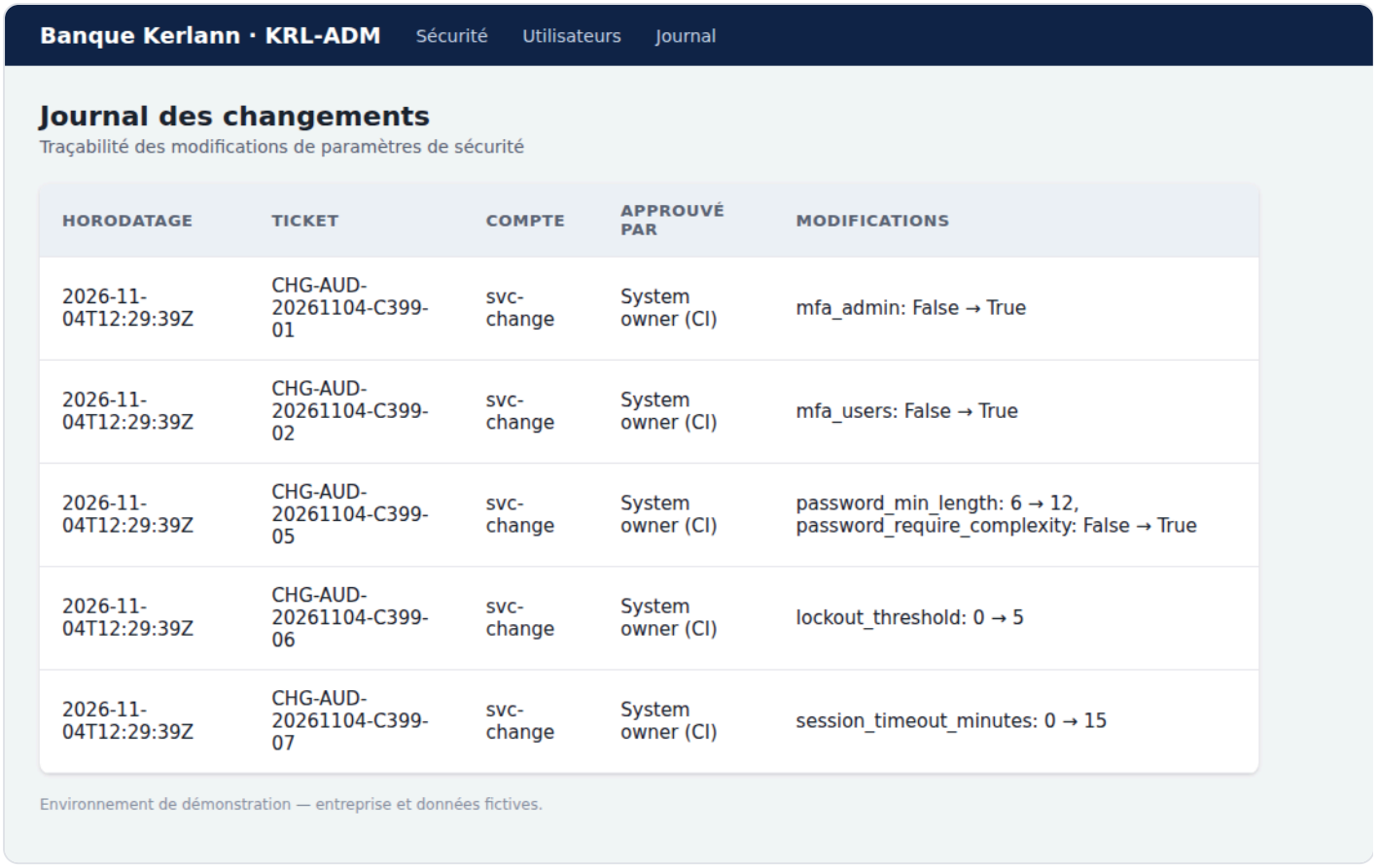
- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

444e47228a060cbb3a21210f902eae510a61814c72d5468b0911269f1eeb5f24

E. Change log of the audited system



SHA-256 4289438599f269956ba978ff71d4f12c78b28cbd0fc84e886fd356b574bfa0e4

F. Framework coverage

21 requirements read: 12 tested automatically (7 controls; 5 regulation clauses covered through the policy), 9 left to document review, 0 to interviews, 0 rejected for lack of an exact quote. Attest only covers the first group.

REF.	TEXT (VERIFIED QUOTE)	TESTABILITY	CONTROL	
DORA 9(4)(c)	« implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies »	**tested automatically**	→ PSI-4.4, PSI-4.5, PSI-4.7	Testable here through lockout, session and generic-account settings checked by the covering policy controls.
DORA 9(4)(d)	« implement policies and protocols for strong authentication mechanisms, based on relevant standards and dedicated control systems, and protection measures of cryptographic keys whereby data is encrypted based on results o »	**tested automatically**	→ PSI-4.1, PSI-4.2, PSI-4.3	Testable here through MFA and password settings checked by the covering policy controls.
DORA 9(4)(e)	« implement documented policies, procedures and controls for ICT change management, including changes to software, hardware, firmware components, systems or security parameters, that are based on a risk assessment approach »	**document review**	0	Not testable here because the read-only interface shows only journal entries, not documented policies for testing and assessment.
DORA 9(4)(f)	« have appropriate and comprehensive documented policies for patches and updates. »	**document review**	0	Not testable here because the read-only interface exposes no patch policy documents.

RTS 21(1)(a)	« the assignment of access rights to ICT assets based on need-to-know, need-to-use and least privilege principles; »	**document review**	0	Not testable here because the user list shows roles but not the need-to-know justification.
RTS 21(1)(b)	« the segregation of duties designed to prevent unjustified access to critical data […]; »	**document review**	0	Not testable here because segregation rules require policy and role-design review beyond the user list.
RTS 21(1)(c)	« a provision on user accountability, by limiting to the extent possible the use of generic and shared user accounts; »	**tested automatically**	→ PSI-4.7	Testable here through the admin user inventory checked by the covering policy control.
RTS 21(1)(d)	« a provision on restrictions of access to ICT assets, setting out controls and tools to prevent unauthorised access; »	**document review**	0	Not testable here because the generic provision requires document review of controls and tools.
RTS 21(1)(e)	« account management procedures to grant, change or revoke access rights for user and generic accounts, including: »	**document review**	0	Not testable here because procedures require document review beyond the current user list.
RTS 21(1)(e)(ii)	« assignment of privileged, emergency, and administrator access on a need-to-use or an ad-hoc basis for all ICT systems; »	**tested automatically**	→ PSI-4.7	Testable here through the admin user inventory checked by the covering policy control.
RTS 21(1)(e)(iv)	« update of access rights where changes are necessary and at least once a year for all ICT systems […]; »	**document review**	0	Not testable here because the journal shows no access-review periodicity.
RTS 21(1)(f)	« authentication methods, including all of the following: »	**document review**	0	Not testable here because the chapeau requires document review of the authentication policy.
RTS 21(1)(f)(i)	« the use of authentication methods commensurate to the classification established […]; »	**document review**	0	Not testable here because classification mapping requires document review beyond MFA flags.
RTS 21(1)(f)(ii)	« the use of strong authentication methods in accordance with leading practices and techniques for remote access, […] privileged access, for access to ICT assets supporting critical or important functions. »	**tested automatically**	→ PSI-4.1, PSI-4.2	Testable here through MFA enforcement flags and per-user MFA checked by covering controls.
PSI-4.1	« Authentification multifacteur obligatoire pour tout compte à privilèges (administrateur). »	**tested automatically**	1	Testable here because the security API and user list expose MFA enforcement and per-admin MFA status.
PSI-4.2	« Authentification multifacteur obligatoire pour les utilisateurs d'un système supportant une fonction critique ou importante. »	**tested automatically**	1	Testable here because KRL-ADM supports critical functions and exposes MFA flags and per-user MFA.
PSI-4.3	« Mot de passe de 12 caractères minimum, avec exigence de complexité. »	**tested automatically**	1	Testable here because the security API exposes minimum length and complexity flags.

PSI-4.4	« Verrouillage du compte après 5 échecs de connexion au plus (et jamais désactivé). »	**tested automatically**	1	Testable here because the security API exposes lockout threshold with 0 meaning never.
PSI-4.5	« Expiration des sessions inactives après 15 minutes au plus (et jamais désactivée). »	**tested automatically**	1	Testable here because the security API exposes session timeout with 0 meaning never.
PSI-4.6	« Journalisation de toutes les actions d'administration. »	**tested automatically**	1	Testable here because the security API exposes the admin audit logging flag.
PSI-4.7	« Aucun compte générique ou partagé ne dispose de droits d'administration. »	**tested automatically**	1	Testable here because the user list exposes login, email and role for generic-account detection.